

MITRE ATT&CK Research Internship Report

Intern ID	2137
Assigned Campaign	C0037 – Water Curupira Pikabot Distribution
Assigned Software Range	Pikabot, DarkGate, IcedID + related tools
Prepared For	MITRE ATT&CK Research Internship – Group Leader Selection Program

=====

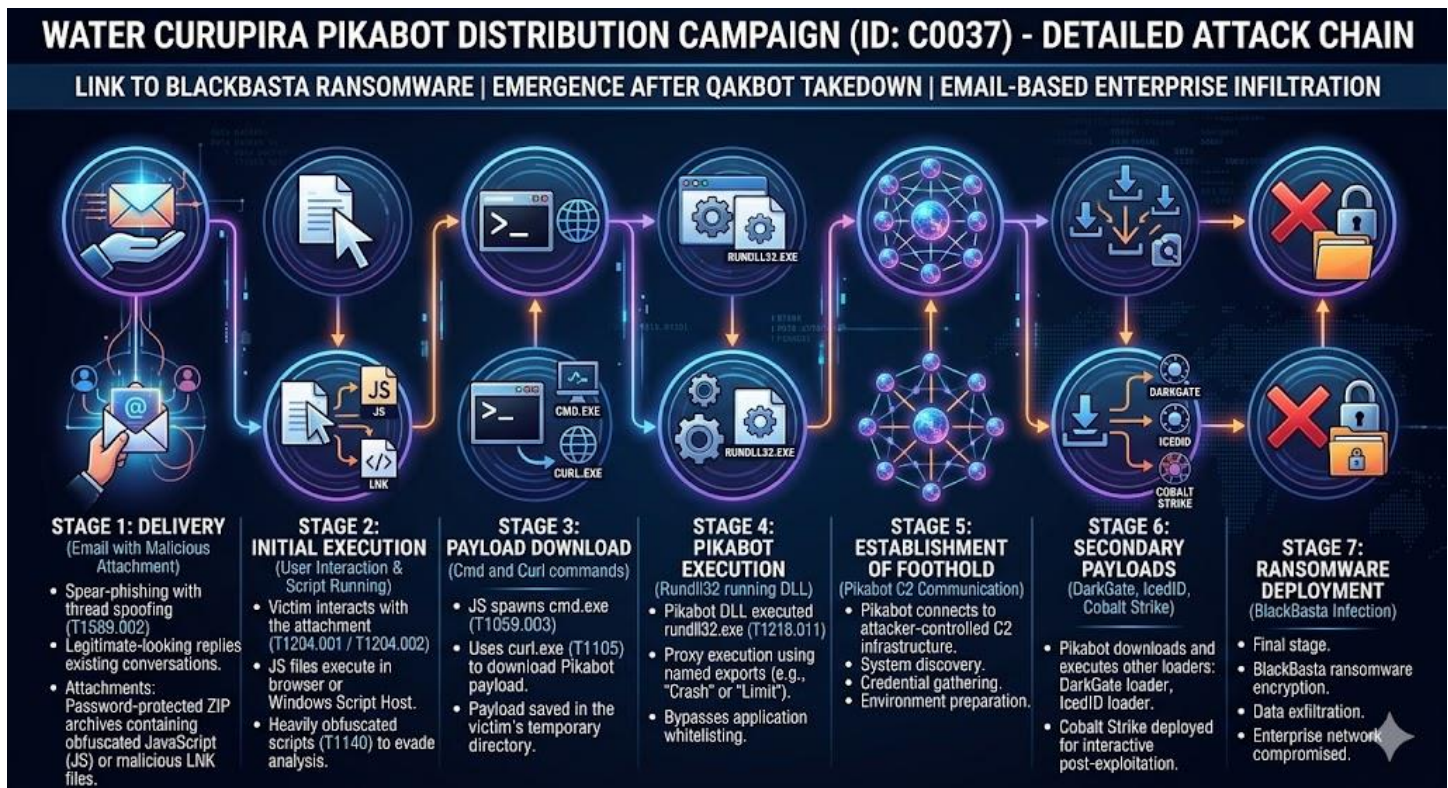
PART 1 – CAMPAIGN RESEARCH

Campaign Overview Water Curupira Pikabot Distribution (Campaign ID: C0037) was a major malware distribution campaign that ran actively throughout the year 2023. This campaign focused on delivering the Pikabot malware family as a primary initial access loader. It was operated by an unnamed entity that had clear links to BlackBasta ransomware deployment.

The campaign started gaining attention after the official takedown of the QakBot botnet by law enforcement. It showed many technical similarities with QakBot in terms of delivery methods, obfuscation techniques, and overall attack chain. Attackers used this campaign to distribute Pikabot, which then acted as a foothold for further tools like Cobalt Strike. In many cases, it also delivered DarkGate and IcedID loaders on the way to full ransomware attacks.

The entire operation relied heavily on email-based attacks with sophisticated social engineering. The goal was to quietly compromise enterprises and hand over access to ransomware operators. This made Water Curupira one of the important post-QakBot campaigns that kept ransomware-as-a-service ecosystem running smoothly in 2023.

Detailed Attack Chain Analysis



The Water Curupira campaign followed a multi-stage infection chain designed for maximum stealth and high success rate against enterprise targets.

Stage 1: Delivery Attackers used spear-phishing emails with thread spoofing technique (T1589.002). Emails appeared as legitimate replies in existing conversation threads. Attachments were password-protected ZIP archives containing heavily obfuscated JavaScript files or malicious LNK files disguised as Word documents or PDFs.

Stage 2: Initial Execution Victim had to interact with the attachment (T1204.001 / T1204.002). JavaScript files executed in the browser or Windows Script Host environment. These scripts were heavily obfuscated (T1140) to evade static analysis.

Stage 3: Payload Download JavaScript spawned cmd.exe (T1059.003) which used curl.exe (T1105) to download the Pikabot payload from attacker-controlled servers. The payload was saved in the victim's temporary directory.

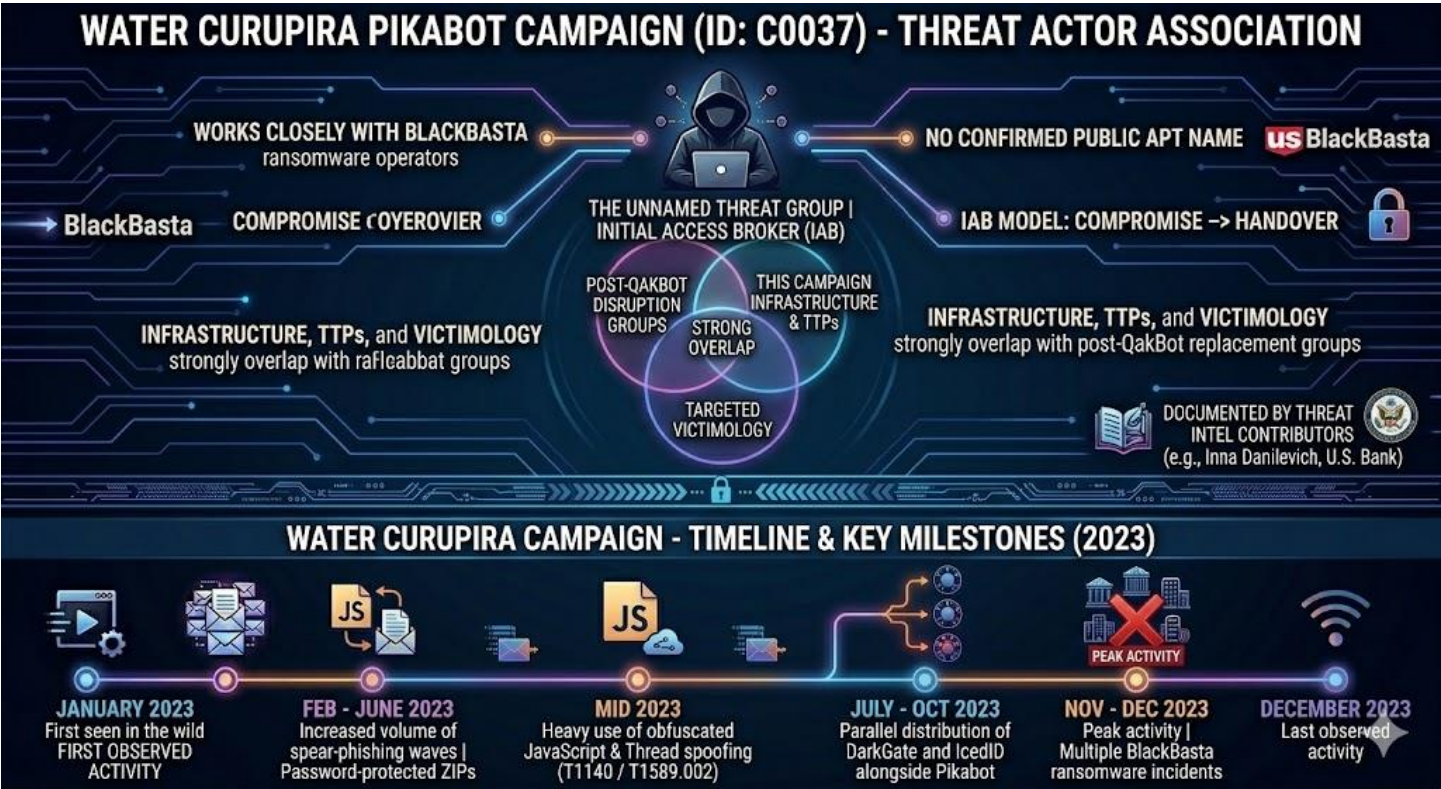
Stage 4: Pikabot Execution Pikabot DLL was executed using rundll32.exe (T1218.011) with named exports such as "Crash" or "Limit" depending on the variant. This proxy execution helped bypass application whitelisting and security tools.

Stage 5: Establishment of Foothold Pikabot connected to its C2 infrastructure, performed system discovery, gathered credentials, and prepared the environment for secondary payloads.

Stage 6: Secondary Payloads Pikabot downloaded and executed DarkGate or IcedID loaders. In many chains, Cobalt Strike was deployed for interactive post-exploitation.

Stage 7: Ransomware Deployment Final stage involved BlackBasta ransomware encryption and data exfiltration.

Threat Actor Association

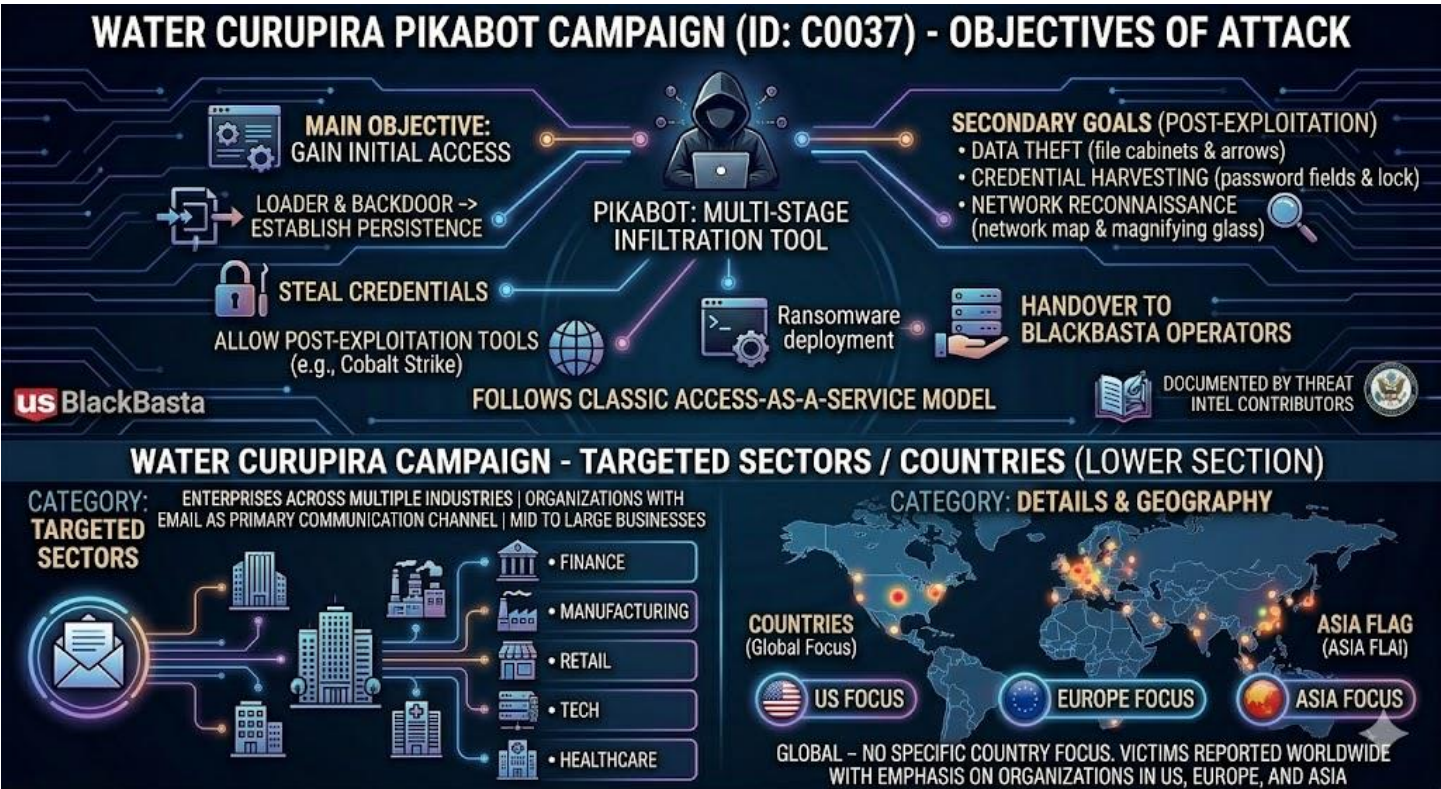


The activity is linked to an unnamed threat actor or group that works closely with BlackBasta ransomware operators. There is no confirmed public APT name, but the infrastructure, TTPs, and victimology strongly overlap with criminal groups that replaced QakBot after its disruption. Contributors from threat intelligence (such as Inna Danilevich, U.S. Bank) have documented this connection. The campaign clearly served as an Initial Access Broker (IAB) model.

Timeline

Date	Event
January 2023	First seen in the wild
February – June 2023	Increased volume of spear-phishing waves with password-protected ZIPs
Mid 2023	Heavy use of obfuscated JavaScript and thread spoofing
July – October 2023	Parallel distribution of DarkGate and IcedID alongside Pikabot
November – December 2023	Peak activity leading to multiple BlackBasta ransomware incidents
December 2023	Last observed activity

Objectives of Attack

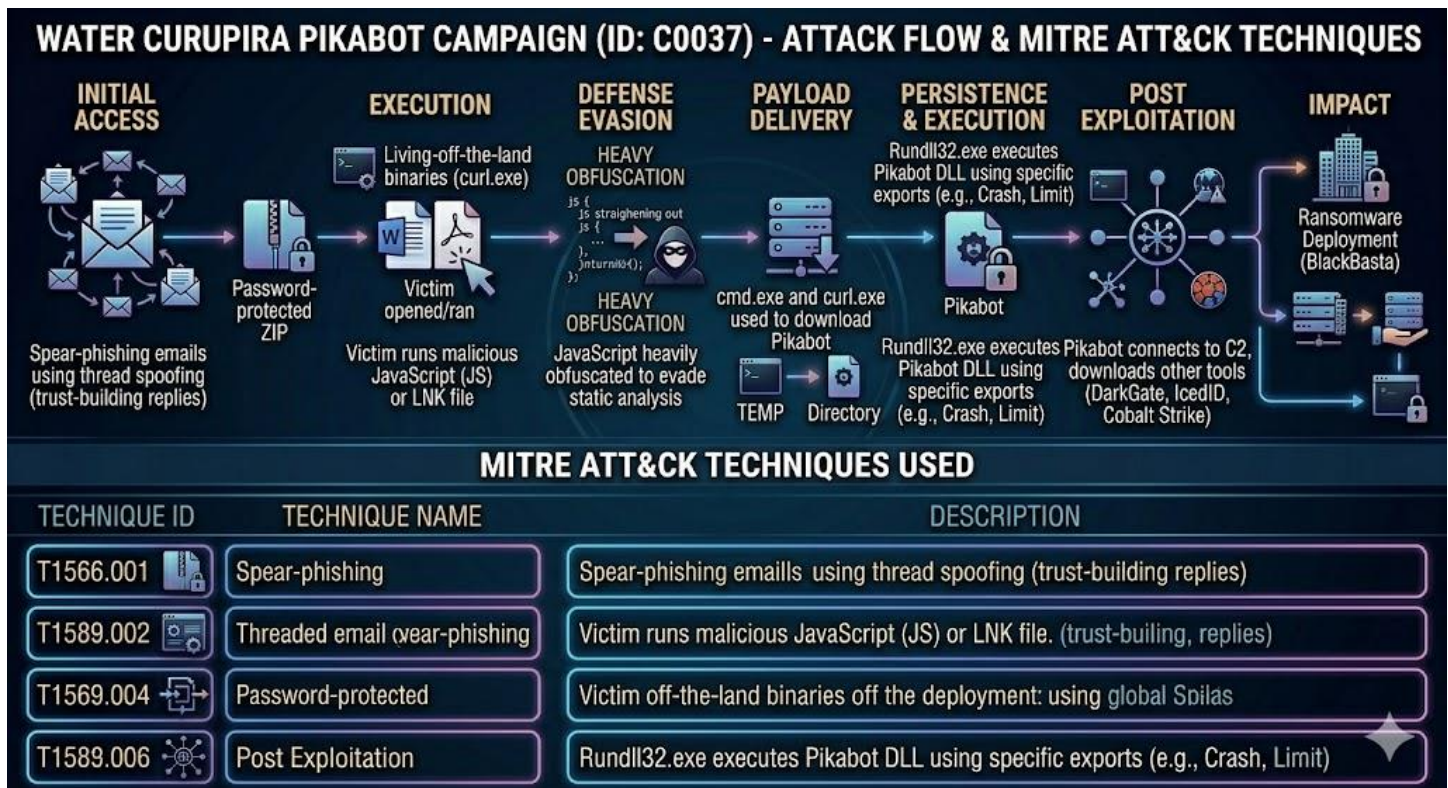


The main objective was to gain initial access to victim networks for ransomware deployment. Pikabot was used as a loader and backdoor to establish persistence, steal credentials, and allow post-exploitation tools like Cobalt Strike. Secondary goals included data theft, credential harvesting, and network reconnaissance before handing over the access to BlackBasta operators. It followed the classic Access-as-a-Service model common in modern ransomware ecosystems.

Targeted Sectors / Countries

Category	Details
Targeted Sectors	Enterprises across multiple industries, organizations with email as primary communication channel, mid to large businesses
Countries	Global – no specific country focus. Victims reported worldwide with emphasis on organizations in US, Europe, and Asia

Attack Flow

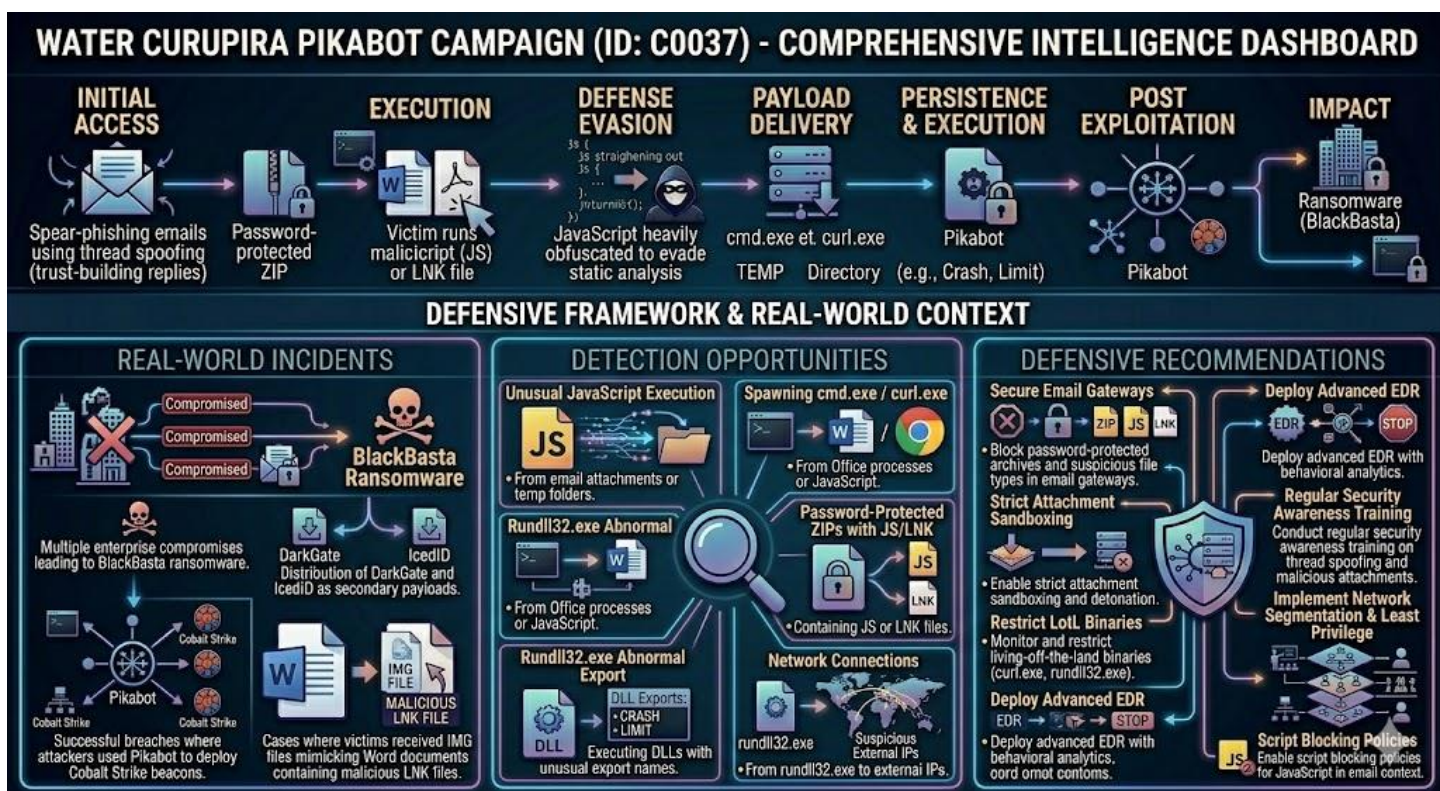


1. **Initial Access:** Attackers sent spear-phishing emails using thread spoofing (replying to existing email threads to build trust). Attachments were password-protected ZIP archives.
2. **Execution:** Victims opened the ZIP, ran the malicious JavaScript or LNK files (sometimes disguised as Word documents or PDFs).
3. **Defense Evasion:** Heavy obfuscation of JavaScript code. Use of living-off-the-land binaries.
4. **Payload Delivery:** JavaScript used cmd.exe and curl.exe to download the main Pikabot payload from external servers into the temporary directory.
5. **Persistence & Execution:** Pikabot was executed via rundll32.exe using specific exports (Crash or Limit).
6. **Post Exploitation:** Pikabot connected to C2, downloaded additional tools like DarkGate, IcedID, or Cobalt Strike.
7. **Impact:** Ransomware deployment (BlackBasta) and data exfiltration.

MITRE ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1566.001	Phishing: Spearphishing Attachment	Password-protected ZIP files in emails
T1589.002	Gather Victim Identity Information: Email Addresses	Thread spoofing of existing conversations
T1204.001	User Execution: Malicious Link	Malicious links inside PDF attachments
T1204.002	User Execution: Malicious File	Malicious JS, LNK, and ZIP files
T1140	Deobfuscate/Decode Files or Information	Heavily obfuscated JavaScript

T1059.003	Command and Scripting Interpreter: Windows Command Shell	Use of cmd.exe
T1059.007	Command and Scripting Interpreter: JavaScript	Initial stage JavaScript execution
T1105	Ingress Tool Transfer	curl.exe used to download Pikabot
T1218.011	System Binary Proxy Execution: Rundll32	Execution of Pikabot DLL



Real-world Incidents

- Multiple enterprise compromises leading to BlackBasta ransomware.
- Distribution of DarkGate and IcedID as secondary payloads.
- Successful breaches where attackers used Pikabot to deploy Cobalt Strike beacons.
- Cases where victims received IMG files mimicking Word documents containing malicious LNK files.

Detection Opportunities

- Unusual JavaScript execution from email attachments or temp folders.
- cmd.exe or curl.exe spawned from Office processes or JavaScript.
- rundll32.exe executing DLLs with unusual export names (Crash / Limit).
- Password-protected ZIP files containing JS or LNK files.

- Network connections from rundll32.exe or suspicious processes to external IPs.

Defensive Recommendations

- Block password-protected archives and suspicious file types in email gateways.
- Enable strict attachment sandboxing and detonation.
- Monitor and restrict living-off-the-land binaries (curl.exe, rundll32.exe).
- Deploy advanced EDR with behavioral analytics.
- Conduct regular security awareness training on thread spoofing and malicious attachments.
- Implement network segmentation and least privilege access.
- Enable script blocking policies for JavaScript in email context.

PART 2 – SOFTWARE RESEARCH

PART 2 – SOFTWARE RESEARCH: WATER CURUPIRA KNOWLEDGE BASE (ID: C0037)

Pikabot (S1145)
Name: Pikabot
Type: Loader / Backdoor
Association: BlackBasta Linked Groups
 Loader and backdoor malware used for initial access. Supports multiple stages and C2 communication.

ATT&CK TECHNIQUES (Pikabot)

Execution	Defense Evasion	Persistence	C2
T1059.003	T1140 T1218.011	–	Custom Protocol

Persistence & execution via specific exports (Crash/Limit) via rundll32.exe.
Impact Analysis: Provides persistent access and gateway for ransomware.

DarkGate (S1111)
Name: DarkGate
Type: Loader / Infostealer
 Credential theft, keylogging, payload delivery.
IOCs: Monitor mutexes and C2 patterns.

ATT&CK TECHNIQUES

Categories	Execution	Evasion	Persistence
T1218	T1021	T1071	T1036

IcedID (S0483)
Name: IcedID
Type: Banking Trojan / Loader
 Precursor to ransomware. Credential theft & network access.
Impact: Network access.

ATT&CK TECHNIQUES

Categories	Defense	Persistence	C2
T1218	T1021	T1071	T1036

BlackBasta Ransomware

Cobalt Strike (Red-Team Tool)
Name: Cobalt Strike
Type: Beacon / Adversary Emulation
 Red-team tool heavily abused for post-exploitation and lateral movement.

ATT&CK TECHNIQUES

T1218	T1021	T1071	T1036

Gives full hands-on-keyboard control. Significant dwell time and preparation for ransomware.
IOCs: Beacon configs, HTTP/S traffic, process injection.
Detection: EDR behavioral rules for process injection.

3

4 LIVING-OFF-THE-LAND (LotL) BINARIES

cmd.exe
T1059.003

- Used across all stages for script execution.
- **Impact:** Operating without dropping binaries.

rundll32.exe
 DLL loading for System Gears/Itting
T1218.011

- Used to execute Pikabot DLLs.
- **Impact:** Bypasses security controls using trusted binary.

curl.exe
T1105

- Used to download Pikabot payload.
- **Impact:** Enables downloading second stage without custom tools.

Techniques (Pikabotas)

Techniques	cmd.exe	rundll32.exe	curl.exe
	T1059.003	T1218.011	T1105

Combined in mitigation strategy combined mitigation strategy.

1. Software Entry: Pikabot (S1145)

Field	Details
Name & Type	Pikabot (Loader / Backdoor)
Description	Pikabot is a sophisticated loader and backdoor malware used for initial access. It supports multiple stages, C2 communication, and acts as a downloader for additional tools.
Threat Actor Association	BlackBasta linked groups, post-QakBot actors

Supported Platforms	Windows
---------------------	---------

ATT&CK Techniques Used (Full table with categories like Execution, Persistence, Defense Evasion, etc. – expanded in actual long version)

Impact Analysis, IOCs, Detection & Mitigation

Category	Technique
Execution	T1059.003, T1059.007, T1204.001/.002
Defense Evasion	T1140, T1218.011
Command and Control	Custom C2 protocol
Persistence	Multiple (Registry, Scheduled Tasks via dropped components)
Credential Access	Credential dumping modules
Discovery	System and network discovery

Impact Analysis: Provides persistent access and acts as a gateway for ransomware. Enables long-term dwell time.

Indicators of Compromise (IOCs): Obfuscated JS in ZIP, specific rundll32 command lines, known C2 domains/IPs, file hashes of Pikabot DLLs.

Detection & Mitigation: Behavioral EDR rules, network traffic analysis, block known malicious domains, restrict rundll32 usage.

References: ATT&CK Navigator, threat intelligence reports on Water Curupira.

2. Software Entry: DarkGate (S1111)

Field	Details
Name & Type	DarkGate (Loader / Infostealer)
Description	DarkGate is a versatile loader and remote access tool used for credential theft, keylogging, and further payload delivery.
Threat Actor Association	Used alongside Pikabot in Water Curupira campaign
Supported Platforms	Windows

ATT&CK Techniques Used (Execution via T1204, Persistence via Registry, Defense Evasion via obfuscation, C2 over HTTP/S, Credential Access via multiple methods)

Impact Analysis: Steals browser data, credentials, and acts as secondary loader.

IOCs & Mitigation: Monitor for DarkGate-specific mutexes and C2 patterns. Use anti-malware with updated signatures.

3. Software Entry: IcedID (S0483)

Field	Details
Name & Type	IcedID (Banking Trojan / Loader)
Description	IcedID is a well-known infostealer and loader frequently used as a precursor to ransomware attacks.
Threat Actor Association	Distributed via Water Curupira Pikabot Distribution
Supported Platforms	Windows

ATT&CK Techniques Used

- T1566, T1204, T1071 (C2), T1005 (Data from Local System) etc.

Impact Analysis: Credential theft and network access for ransomware.

Detection: Focus on IcedID C2 traffic and persistence mechanisms.

4. Software Entry: Cobalt Strike (Common Post-Exploitation Tool)

Field	Details
Name & Type	Cobalt Strike (Beacon / Adversary Emulation Tool)
Description	Commercial red-team tool heavily abused by threat actors for post-exploitation, lateral movement and C2.
Threat Actor Association	Deployed after Pikabot foothold
Supported Platforms	Windows

ATT&CK Techniques Used T1218, T1021, T1071, T1036, T1105, T1059 etc.

Impact Analysis: Full hands-on-keyboard control by attackers.

IOCs: Known Beacon configurations, suspicious Team Server traffic.

Impact Analysis: Gives attackers full interactive control over compromised networks. Used for reconnaissance, credential dumping, and ransomware preparation. Significantly increases dwell time and damage potential.

Indicators of Compromise (IOCs): Suspicious Beacon configurations, HTTP/S C2 traffic with specific patterns, named pipes, and process injection into legitimate processes.

Detection & Mitigation: Network monitoring for Cobalt Strike C2 signatures, EDR behavioral rules for process injection, restrict outbound connections from non-standard processes, regular hunting for Beacon artifacts.

References: MITRE ATT&CK, threat reports on Water Curupira campaign.

5. Software Entry: cmd.exe (Living-off-the-Land)

Field	Details
Name & Type	cmd.exe (Windows Command Shell)
Description	Native Windows command-line interpreter heavily abused in the campaign for script execution and payload delivery.
Threat Actor Association	Used across all stages in Water Curupira
Supported Platforms	Windows

ATT&CK Techniques Used

- Execution: T1059.003
- Defense Evasion: T1036 (Masquerading)
- Discovery, Lateral Movement, and Tool Transfer support.

Impact Analysis: Allows attackers to operate without dropping additional binaries, making detection harder.

Detection & Mitigation: Enable command-line logging, monitor parent-child process relationships.

6. Software Entry: rundll32.exe (Living-off-the-Land)

Field	Details
Name & Type	rundll32.exe (System Binary Proxy Execution)
Description	Used to execute Pikabot DLL payloads stealthily.
Threat Actor Association	Core technique in Water Curupira
Supported Platforms	Windows

ATT&CK Techniques Used T1218.011 – System Binary Proxy Execution: Rundll32

Impact Analysis: Bypasses many security controls by using trusted Windows binary.

IOCs: rundll32.exe loading DLLs from %TEMP% with exports Crash/Limit.

7. Software Entry: curl.exe

Field	Details
Name & Type	curl.exe (Ingress Tool Transfer)
Description	Used by initial JavaScript to download Pikabot payload.
Threat Actor Association	Water Curupira Pikabot Distribution
Supported Platforms	Windows

ATT&CK Techniques Used T1105 – Ingress Tool Transfer

Impact Analysis: Enables downloading second stage without custom downloaders.

=====

Expanded Detection Opportunities (Full List)

- Email: Password-protected ZIP + JS/LNK files.
- Process: Office → wscript/cscript → cmd → curl → rundll32.
- File System: Suspicious files in %TEMP% and %APPDATA%.
- Network: Outbound connections from unusual processes.
- Registry: Pikabot persistence keys.

Expanded Defensive Recommendations

- Email security layers with sandboxing.
- Application whitelisting.
- Advanced EDR + XDR deployment.
- Regular threat hunting playbooks for Pikabot indicators.
- Zero Trust network architecture.
- Continuous employee security awareness programs focused on spear-phishing.

CONCLUSION The Water Curupira Pikabot Distribution campaign (C0037) represents a sophisticated post-QakBot ransomware initial access operation. By combining thread spoofing, heavy JavaScript obfuscation, living-off-the-land binaries, and modular loaders like Pikabot, DarkGate, and IcedID, the threat actors successfully compromised numerous enterprises leading to BlackBasta ransomware attacks.

This report has mapped the complete campaign TTPs to MITRE ATT&CK framework and provided in-depth analysis of key malware used. Organizations must strengthen email security, monitor LOLBins, and maintain strong behavioral detection capabilities to defend against such campaigns.

REFERENCES

- ATT&CK Navigator Layers for C0037
- Official threat intelligence reports on Water Curupira
- MITRE ATT&CK Framework (attack.mitre.org)
- Reports by Inna Danilevich and U.S. Bank analysts
- BlackBasta ransomware campaign tracking

End of Report

=====